Pruebas de seguridad de software

Informe técnico - laboratorio de expedientes sintéticos

Curso: ISW-622, Pruebas de Software | **Grupo:** SC-02

Integrante identificado: Byron Bolaños Zamora | **Entrega:** 27/10/2026 | **Versión:** 1.0

Alcance: motor Python y API HTTP local 127.0.0.1:8765; consulta/modificación de notas de Central y Pacífico, autenticación didáctica y auditoría. Solo datos ficticios; sin nube ni pruebas a sistemas reales.

1. Activos, datos y amenazas

Activos: A1 expedientes; A2 calificaciones; A3 sesiones y tokens didácticos; A4 roles/permisos por sede; A5 bitácora; A6 API local.

Flujo de datos: cliente local -> API (encabezado Bearer simulado + ruta/JSON) -> validador de sesión -> autorización por rol y sede -> expedientes en memoria -> registro de auditoría sin secretos -> respuesta JSON. Los fallos no entregan notas.

Riesgo	Actor, abuso y activo	Impacto / prioridad
R-01	Estudiante consulta el expediente ajeno (A1, A2).	Divulgación de nota; alta.
R-02	Docente cambia la nota de otra sede (A2, A4).	Alteración de datos; alta.
R-03	Portador reutiliza sesión revocada o expirada (A3).	Acceso indebido; crítica.
R-04	Docente envía nota inválida fuera de rango (A2).	Integridad afectada; alta.
R-05	El sistema registra token de acceso en auditoría (A3, A5).	Exposición credencial; media.
R-06	Administrador modifica nota pese a ser de solo lectura (A2, A4).	Elevación de permisos; alta.

Prioridades basadas en impacto de confidencialidad, integridad y probabilidad de explotación con tokens locales sintéticos.

2. Requisitos observables

ID	Requisito verificable / oráculo
SEC-01	Estudiante solo lee su expediente y docente solo su sede; otro recurso devuelve 403 sin nota.
SEC-02	Docente solo cambia calificación de su sede; rechazo 403 y valor original intacto.
SEC-03	Sesión ausente, revocada o expirada impide leer/cambiar; 401 sin datos protegidos.
SEC-04	Una nota requiere número finito entre 0 y 100; inválida devuelve 400 y no persiste.
SEC-05	Administrador puede leer ambas sedes (200), pero no modifica notas (403).
SEC-06	Auditoría registra actor, acción, recurso y resultado sin token ni nota.

3. Criterios de aceptación Dado-Cuando-Entonces

CA-01: Dado Ana autenticada, cuando pide 202 de Luis, entonces recibe 403 sin nota y los datos no cambian.

CA-02: Dado un token revocado, cuando solicita 101, entonces recibe 401 sin información académica.

CA-03: Dado María en Central, cuando guarda nota 101 con 101 puntos, entonces recibe 400 y permanece 82.

4. Matriz requisito-riesgo-prueba

Casos	Tipo	Vínculo	Resultado esperado abreviado
TC-01, TC-02	P / N	SEC-01 / R-01	200 propio; 403 ajeno sin nota
TC-03, TC-06	N / P	SEC-02 / R-02	403 otra sede; 200 propia
TC-04, TC-08, TC-10	N / N / N	SEC-03 / R-03	401 revocada, vencida o ausente
TC-05, TC-11, TC-12	F / F / F	SEC-04 / R-04	400 -1; 200 100; 400 101
TC-07, TC-09	P / N	SEC-05 / R-06	200 lectura admin; 403 escritura
EX-AUDIT	Extra	SEC-06 / R-05	Evento sin token ni nota

Catálogo íntegro: *matriz_trazabilidad.csv* incluye precondiciones, entradas exactas, pasos, esperado, evidencia y estado de cada uno de los 12 TC. P = positivo; N = negativo; F = frontera.

5. Diseño, TDD y ejecución

12 casos planificados: 3 positivos, 6 negativos y 3 frontera; los 12 automatizados como pruebas unitarias, más 14 pruebas adicionales (incluidas 8 HTTP de integración). Cada unidad utiliza estado independiente; la API de integración levanta servidor real en 127.0.0.1 con puerto efímero.

Ciclo	ROJO (fallo esperado)	VERDE (cambio mínimo)	REFACTOR (aprobado)
Acceso TC-02	56a838c; 00_access_red.txt: 200 en lugar de 403	24bd50a; 01_access_green.txt: 1 OK	d3488ba; 02_access_refactor.txt: 1 OK
Sesión TC-04	d3488ba; 03_session_red.txt: 200 en lugar de 401	341831b; 04_session_green.txt: 1 OK	70ef2d0; 05_session_refactor.txt: 1 OK

Los hashes son commits reales del repositorio. El código original, incluidos los fallos, se conserva en la historia; no se debilitó ninguna aserción. La regresión completa se ejecutó después de corregir lectura, sesión, escritura y validación.

6. Ejecuciones reproducibles

Entorno: Python 3.13.5, Linux, biblioteca estándar; requisito mínimo Python 3.10. Comando desde laboratorio_seguridad/: `python -m unittest discover -s tests -v`.

Ejecución	Estado limpio	Evidencia
1	26 aprobados; 0 fallidos; ~4 s	evidencias/06_full_run_1.txt
2	26 aprobados; 0 fallidos; ~4 s	evidencias/07_full_run_2.txt

7. Solicitudes HTTP manuales (DAST manual local)

ID	Acción	Observado / evidencia
M-01	GET Ana /expedientes/101	200 con nota propia
M-02	GET María /expedientes/202	403 sin nota; entre sedes
M-03	POST María nota 101 = 101	400; nota rechazada
M-04	GET Ana /expedientes/101 posterior	200; sigue 82
M-05	POST /sesiones/revocar Ana	200; revocada
M-06	GET Ana /expedientes/101 posterior	401; sin nota

Comandos y respuestas HTTP reales: evidencias/09_manual_http.txt. Datos, URLs y tokens exclusivamente ficticios de localhost.

8. Revisión estática (SAST manual)

Inspección sin ejecución de código de negocio: permisos de lectura/escritura por rol y sede; sesión activa; validación numérica, finita y rango; errores 400/401/403 sin notas; auditoría sin tokens; cabecera no-store; servidor loopback. Lista revisada y compilación: evidencias/08_static_check.txt. Las peticiones M-01 a M-06 son pruebas dinámicas, no SAST.

9. Revisión cruzada y usabilidad

Acta: acta_inspeccion.md contiene autor, fecha, política _puede_leer / _puede_cambiar, TC-02 y TC-03; deja constancia de que falta un revisor humano distinto del autor y su firma. La ejecución independiente del README por un compañero también está pendiente; no se simulan participantes ni resultados.

Autorrevisión: OBS-01 (baja): respuestas 403/404 distintas según existencia de ID; riesgo residual documentado. OBS-02 (media): tokens simulados fijos, válidos solo en localhost. OBS-03 (media): estado global en memoria sin persistencia ni transacciones. Acciones: no publicar, no usar con datos reales y documentar límites.

Calidad de pruebas: TC-02 y TC-03 aíslan datos nuevos, verifican denegación, ausencia de nota y estado intacto. Una versión sin política falla (evidencia roja). Se renombraron los dos tests rojos originales a nombres TC-02/TC-04 descriptivos y se precisaron entradas, resultados y mensajes de error.

Usabilidad: una sesión inválida recibe "Sesión inválida o vencida" (401); un usuario identificado sin permisos recibe "Acceso denegado" (403). Ambos textos son comprensibles, distinguen autenticación/autorización y no revelan notas.

10. Hallazgos confirmados y tratamiento

ID	Versión original	Severidad / estado final
H-01	Lectura ajena respondía 200 con nota (TC-02).	Alta; corregido 403 y verificado.
H-02	Sesión revocada respondía 200 (TC-04).	Crítica; corregido 401 y verificado.
H-03	Cambio entre sedes alteraba nota 202 (TC-03).	Alta; corregido 403, valor intacto.
H-04	Nota 101 se almacenaba fuera de rango (TC-12).	Alta; corregido 400, valor intacto.
H-05	Auditoría almacenaba token sintético (EX-AUDIT).	Media; corregido y verificado.
H-06	403/404 permiten inferir existencia de ID.	Baja; abierto y aceptable solo en entorno local.

Hallazgos con reproducción, esperado/observado, tratamiento y evidencia: *hallazgos.csv*. Los resultados anteriores derivan del código original del profesor y de ejecuciones verificadas; no se han maquillado pruebas fallidas.

11. Indicadores y dictamen

Planificados: 12 | **aprobados:** 12 | **fallidos:** 0 | **bloqueados:** 0 | **no ejecutados:** 0. Pruebas adicionales aprobadas: 14.

Tasa de aprobación = 12/(12+0) × 100 = **100 %**. **Avance** = (12+0)/12 × 100 = **100 %**. **Cobertura de requisitos** = 6/6 × 100 = **100 %** (SEC-06 cubierto por EX-AUDIT).

Dictamen: LIBERAR CON CONDICIONES, exclusivamente para demostración didáctica en localhost; NO LIBERAR a producción. Condiciones pendientes: inspección cruzada presencial/real, repetición independiente según README y validación de integración del equipo. Riesgos residuales: IDs inferibles, tokens predefinidos y memoria global. Defecto crítico abierto: ninguno entre los evaluados; existe H-06 menor abierto.

Responsable del dictamen hipotético: Byron Bolaños Zamora, rol de responsable académico del laboratorio; la liberación institucional exigiría aprobación docente. No se garantiza una nota de 100: la rúbrica también exige integrantes reales, revisión cruzada y commits en fechas diferentes.

Uso de IA: apoyo en propuestas de código, diseño de casos, checklist y redacción; contrastado con ejecuciones y evidencias locales. Uso limitado al laboratorio autorizado.